

SSL Pinning Bypass

01/07/2022

Furkan Enes Polatoğlu
furkanenes1160[at]icloud[dot]com

Özet

Windows işletim sistemi üzerinde ADB, Frida, Objection ve Android emülatörü olan NoxPlayer araçlarını kullanarak bir Android uygulaması üzerinde SSL Pinning Bypass işleminin nasıl gerçekleştirildiğini anlatmaya çalışacağım.

Gereksinimler

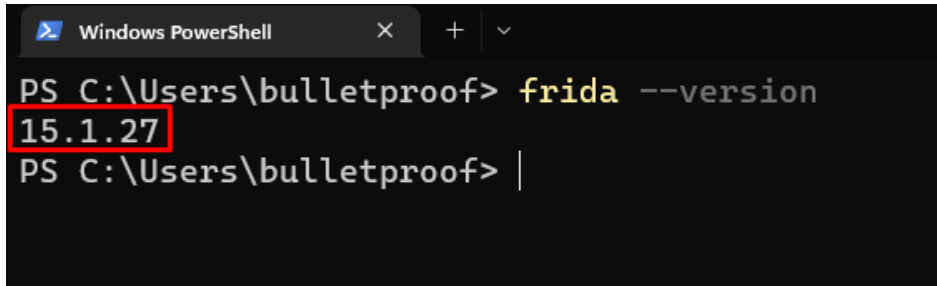
- 1- Frida ve Frida-Server
- 2- NoxPlayer
- 3- Objection
- 4- ADB
- 5- Burp Suite
- 6- Python3

Frida ve Objection Kurulumu

pip (Python paket yükleyici) aracılığıyla Windows üzerine Frida kurularak ardından NoxPlayer'a Frida-server kurulur.

`pip install frida-tools` komutu ile Windows üzerine Frida kurulumu gerçekleştirilir.

`frida --version` komutu ile Frida'nın başarılı bir şekilde kurulduğu onaylanabilir.



```
Windows PowerShell
PS C:\Users\bulletproof> frida --version
15.1.27
PS C:\Users\bulletproof> |
```

`pip install objection` komutu ile Objection kurulumu gerçekleştirilir.

```

Windows PowerShell
PS C:\Users\bulletproof> objection
Usage: objection [OPTIONS] COMMAND [ARGS]...

  _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
 | . | . | | _ | _ | _ | . | | |
 | _ _ _ _ _ | _ _ _ _ _ _ _ | _ | _ _ _ _ _ | _ |
 | _ _ | (object)inject(ion)

Runtime Mobile Exploration
by: @Leonjza from @sensepost

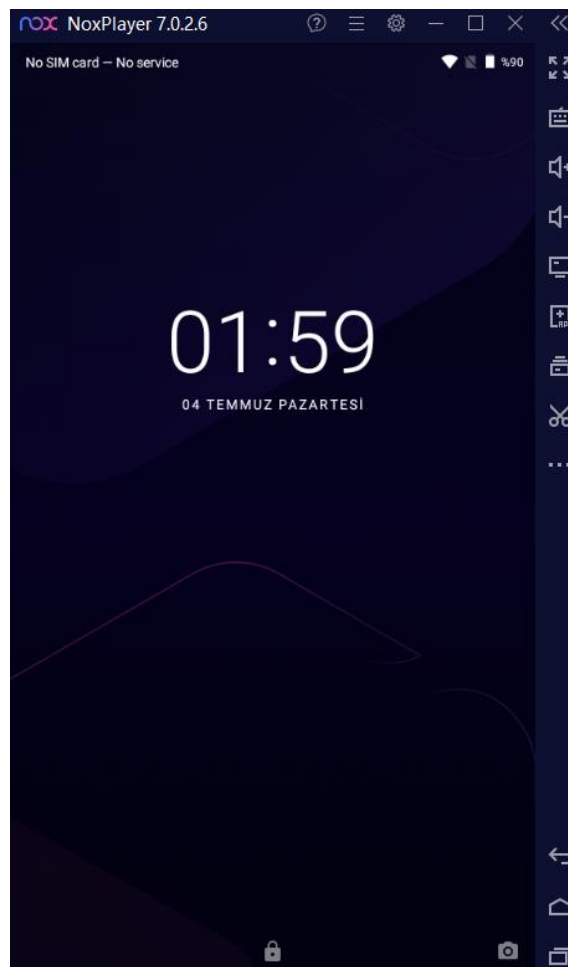
By default, communications will happen over USB, unless the --network option
is provided.

Options:
-N, --network          Connect using a network connection instead of USB.
-h, --host TEXT        [default: 127.0.0.1]
-p, --port INTEGER     [default: 27042]
-ah, --api-host TEXT   [default: 127.0.0.1]
-ap, --api-port INTEGER [default: 8888]
-g, --gadget TEXT      Name of the Frida Gadget/Process to connect to.
                        [default: Gadget]

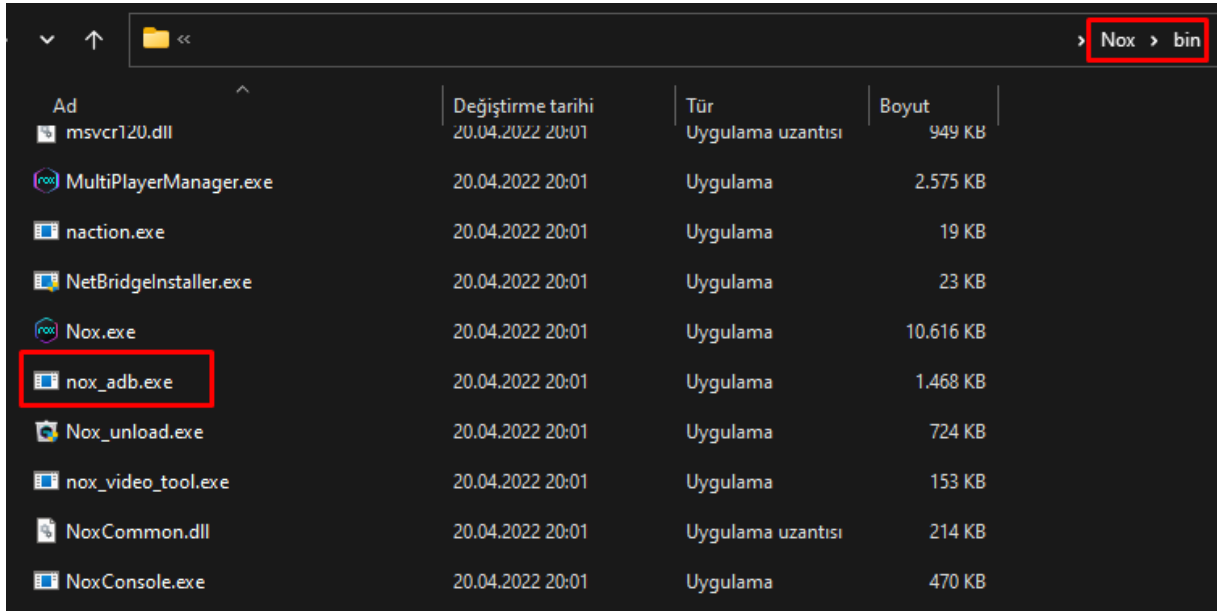
```

ADB Kullanarak NoxPlayer Cihazını Bağlama

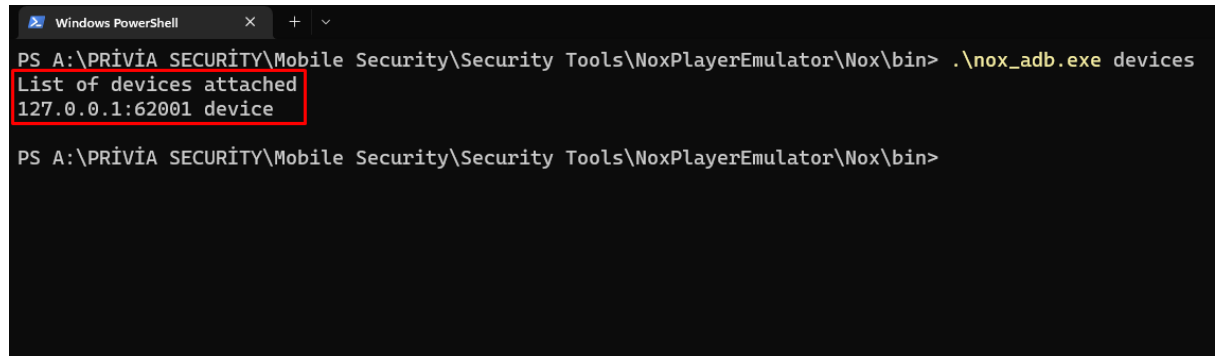
NoxPlayer başlatılarak cihazın root modunun açık olduğundan emin olunmalıdır.



nox_adb.exe, NoxPlayer'ın kurulu olduđu ana dizindeki **bin** klasörü altında bulunur.



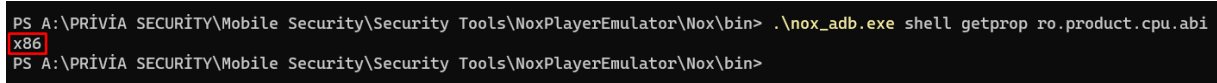
bin dizininde bir PowerShell açılarak, **nox_adb.exe devices** komutu ile bağılı cihazlar kontrol edilir;



Frida-Server Kurulumu

İlk olarak, kullanılan Android cihazın sürümü kontrol edilir. (Burada x86 kullanılmıştır.)

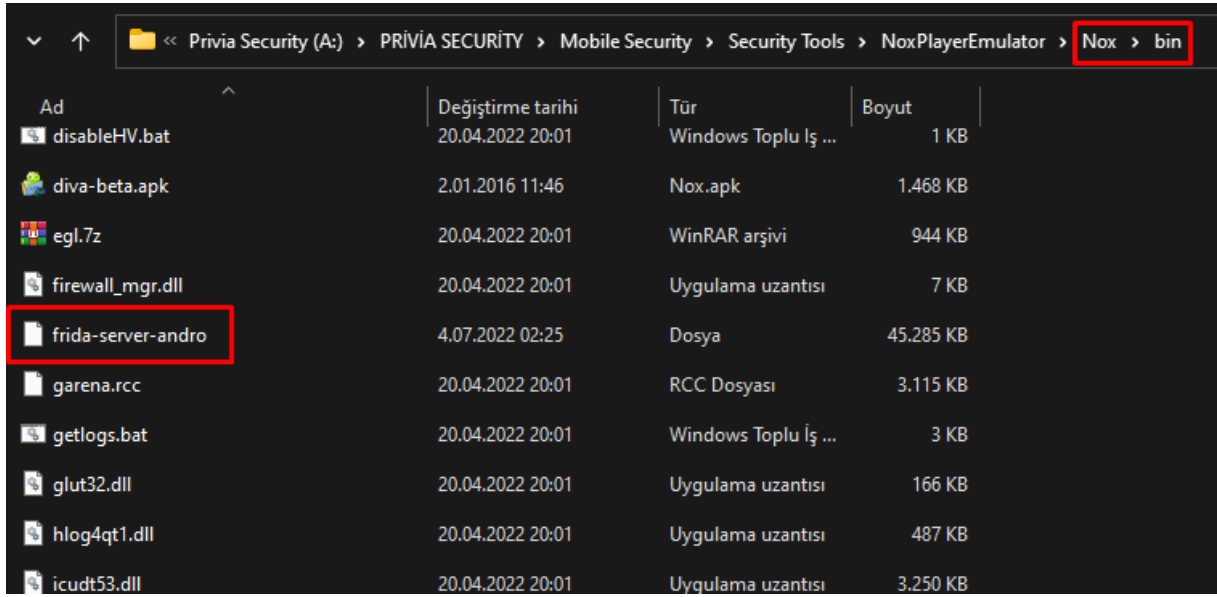
.\nox_adb.exe shell getprop ro.product.cpu.abi



Android x86 için Frida-Server paketi [frida-server-15.1.27-android-x86.xz](https://github.com/frida/frida/releases) aşağıdaki linkten indirilebilir;

<https://github.com/frida/frida/releases>

frida-server-15.1.27-android-x86.xz dosyası **frida-server-andro.xz** olarak yeniden adlandırılarak **../Nox/bin/** dizinine çıkarılır.



frida-server-andro, aşağıdaki komutlar kullanılarak NoxPlayer'a yüklenir.

```
.\nox_adb.exe push .\frida-server-andro /data/local/tmp
.\nox_adb.exe shell "chmod 777 /data/local/tmp/frida-server-andro"
```

```
PS A:\PRİVİA SECURİTY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin> .\nox_adb.exe push .\frida-server-andro /data/local/tmp
[100%] /data/local/tmp/frida-server-andro
PS A:\PRİVİA SECURİTY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin> .\nox_adb.exe shell "chmod 777 /data/local/tmp/frida-server-andro"
PS A:\PRİVİA SECURİTY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin> |
```

Frida-Server başlatılır.

```
.\nox_adb.exe shell "/data/local/tmp/frida-server-andro &"
```

```
PS A:\PRİVİA SECURİTY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin> .\nox_adb.exe shell "/data/local/tmp/frida-server-andro &"
```

NoxPlayer Üzerinde Burp Proxy Ayarı

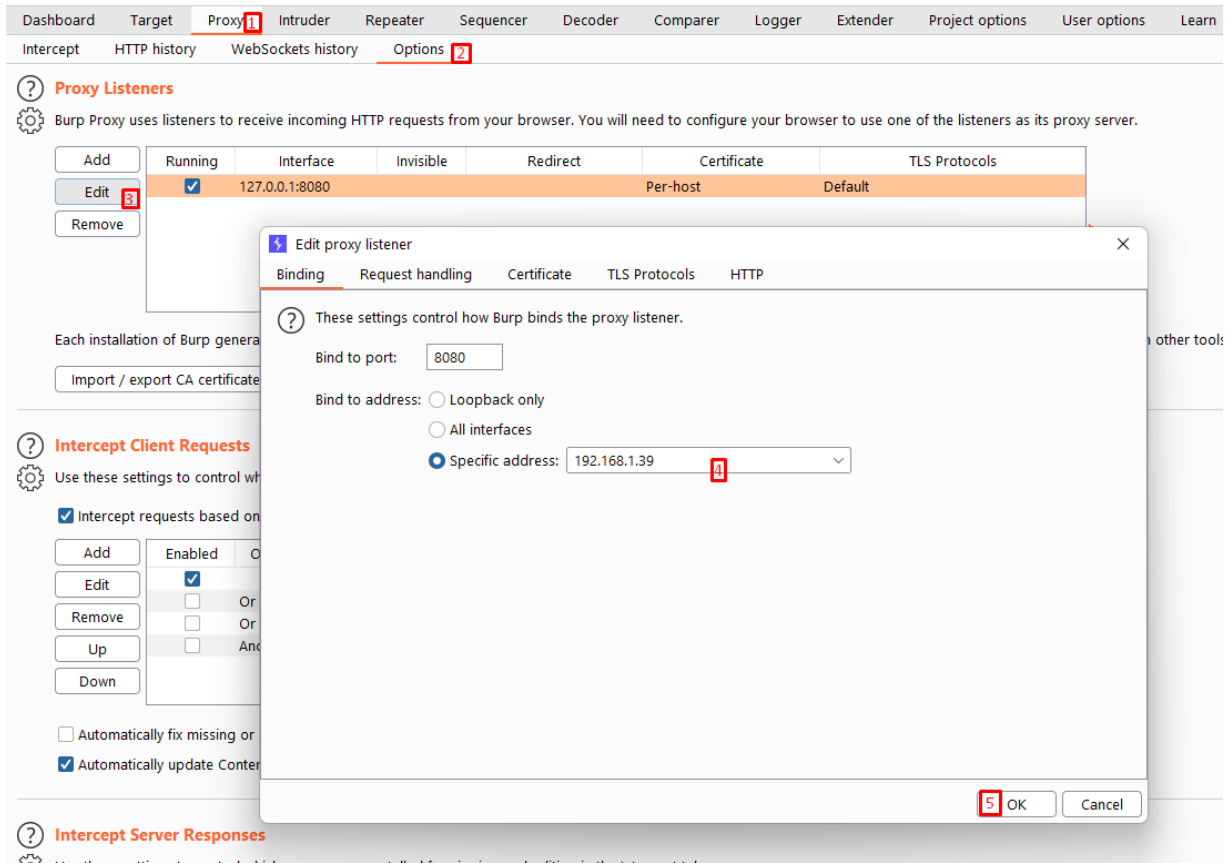
Frida ve Objection hazır olduktan sonra Burp Proxy, NoxPlayer cihazında ayarlanmalıdır. Böylece Burp üzerindeki herhangi bir isteği kesebilecektir.

Komut İstemi (CMD) açılarak "ipconfig" komutu ile ana bilgisayar (Windows) IP adresi kontrol edilir.

```
Wireless LAN adapter Wi-Fi:

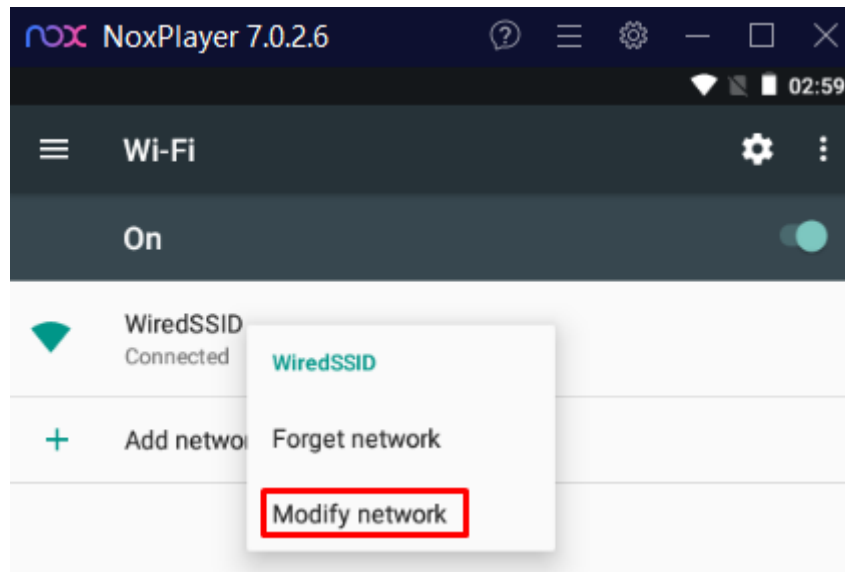
Connection-specific DNS Suffix  . :
Link-local IPv6 Address . . . . . : fe80::5db4:30b9:e0d:3f40%11
IPv4 Address. . . . . : 192.168.1.39
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1
```

Burp Suite açılarak 192.168.1.39 IP adresi ve 8080 portu için bir Proxy Listener eklenir.

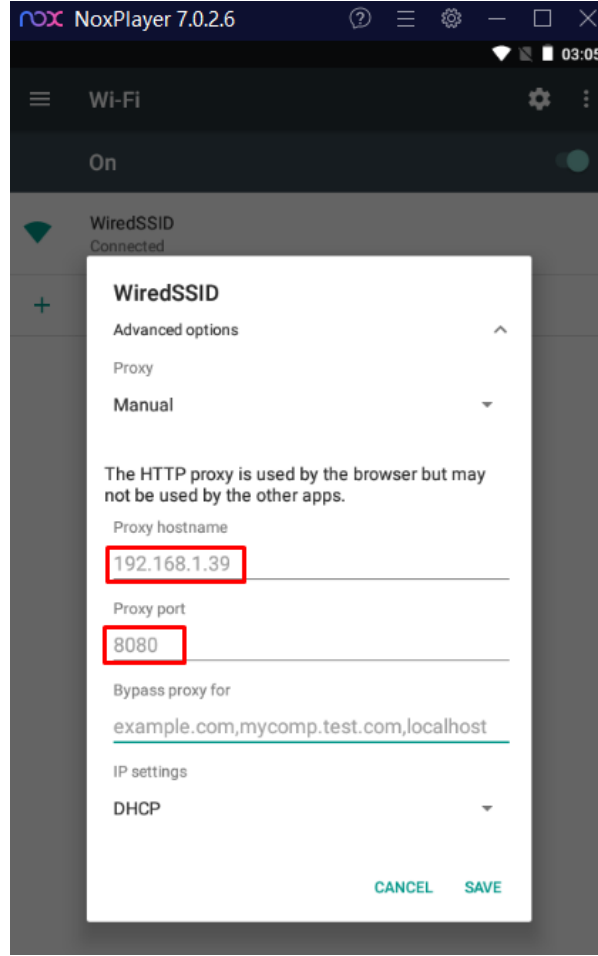


Ardından Android cihaz üzerinde proxy ayarı yapılır.

“Settings > Wifi > WiredSSID” kısmı açılır WiredSSID'de basılı tutulur ve ardından “Modify Network” tıklanır.

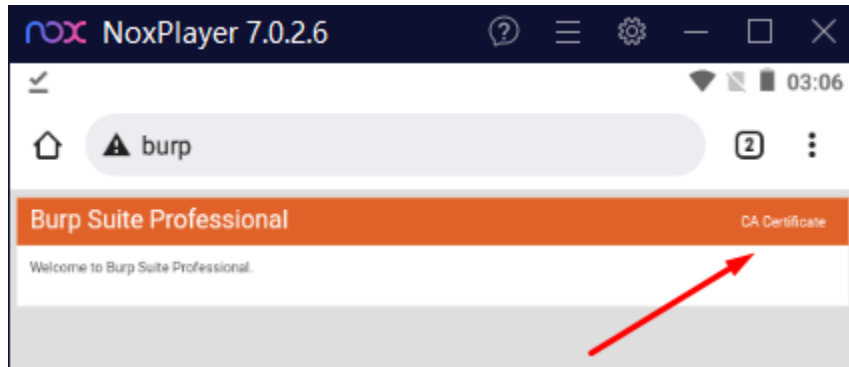


"Advanced Options" seçeneği seçilerek ardından "Manuel" seçeneği seçilir. Ana Bilgisayar(Windows) IP adresi "Proxy hostname" kısmına yazılarak bağlantı noktası 8080 olarak ayarlanır.

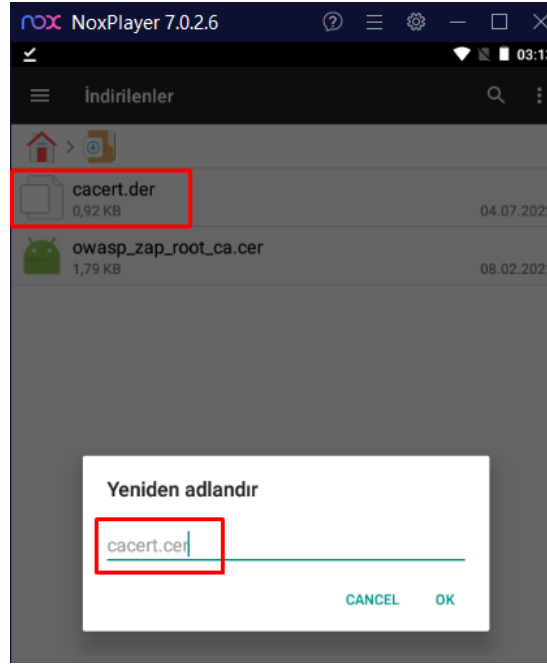


Burp Sertifikası Kurulumu

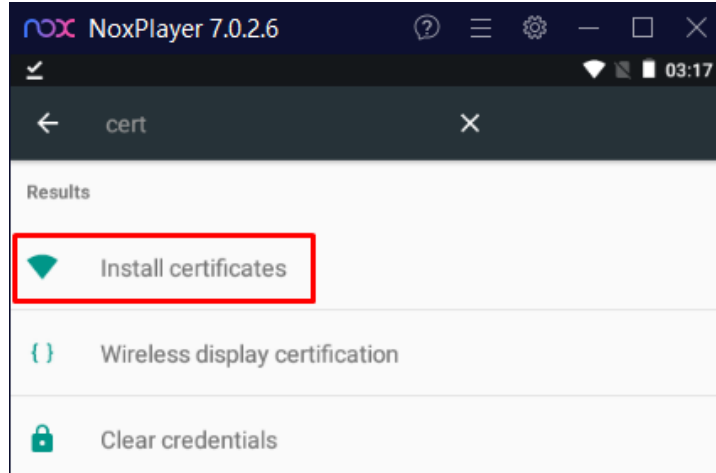
Tarayıcıda <http://burp> adresine gidilerek Burp Sertifikasını indirmek için CA Certificate tıklanır.

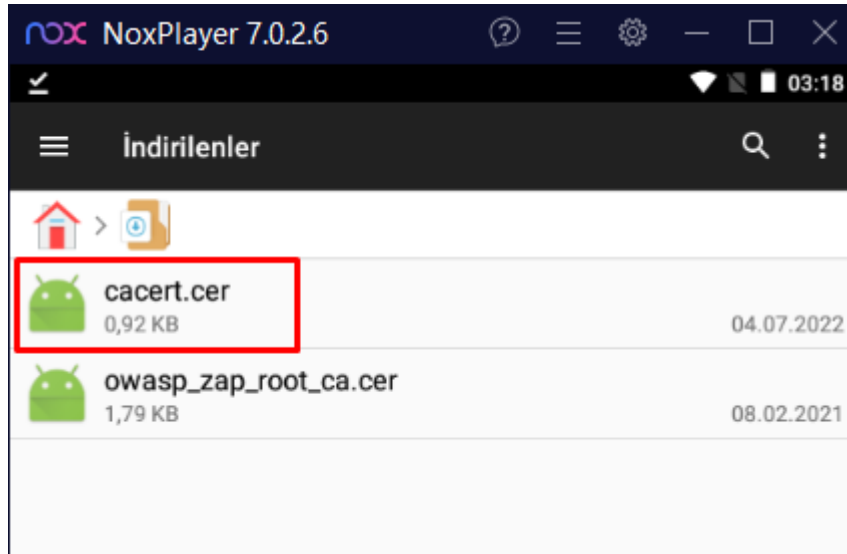
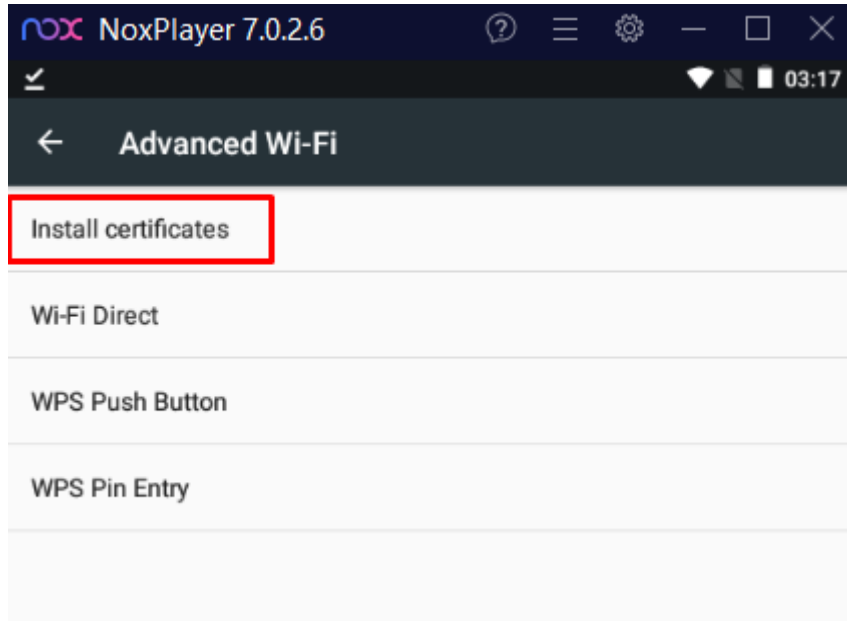


Sertifikayı cacert.der olarak indirecektir, ardından dosya cacert.cer olarak yeniden adlandırılmalıdır.



Ayarlar menüsü açılır ve ardından "**Certificate**" aranır. "**Install Certificates**" ve ardından "**Install Certificates**" seçilir. Son olarak "**cacert.cer**" öğesine tıklanır.





Sertifika adı girildikten sonra Burp sertifika kurulumu tamamlanacaktır.

NOT: Önce Cihaz PIN'ini ayarlamak gerekiyorsa, Cihaz PIN'ini ayarlanmalıdır.

SSL Pinning Bypass

Bu aşamaya kadar sorunsuz bir şekilde ulaştıktan sonra bir SSL Pinning'i atlatmaya çalışabiliriz.

Bu makalede Medium uygulaması ile örnek bir SSL Pinning Bypass denemesi yapacağız. Sizler istediğiniz bir uygulama üzerinde doğrudan inceleme yapabilirsiniz.

İlk olarak Frida ile yüklü uygulamalar kontrol edilmelidir.

`frida-ps -Uai`

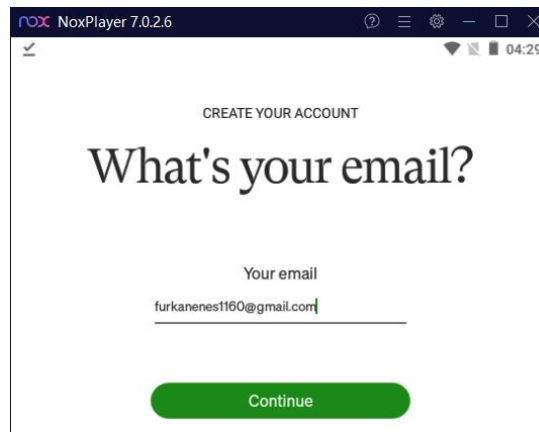
```
Windows PowerShell
PS A:\PRIVIA SECURITY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin> frida-ps -Uai

PID  Name                               Identifier
-----
4342  Chrome                             com.android.chrome
4598  Dosya Yöneticisi +                 com.alphainventor.filemanager
2779  Facebook                           com.facebook.katana
8368  Gallery                            com.android.gallery3d
3731  Google Play Store                  com.android.vending
7699  Paparazzi Apps                     com.paparazziapps.securityapp
2309  Settings                           com.android.settings
-    APK Parser                        com.gmail.heagoo.apkeditor.parser
-    Amaze                             com.amaze.filemanager
-    App Center                       com.android.Calendar
-    BinBin                           com.BINBIN
-    Browser                          com.android.browser
-    Camera                           com.android.camera2
-    Diva                             jakhar.aseem.diva
-    Files                            com.android.documentsui
-    Firefox                          org.mozilla.firefox
-    Google Play Games                com.google.android.play.games
-    GoogleSign                       com.pekall.fmradio
-    Hop                              com.hoplaqit.rider
-    Medium                           com.medium.reader
-    PandaVPN                         com.pandavpnfree.androidproxy
-    Root Checker                     org.freeandroidtools.root_checker
-    Superpedestrian                  com.superpedestrian.link
-    Telegram                         org.telegram.messenger
-    Tutorials                        com.android.calculator2
-    WhatsApp                         com.whatsapp
-    drozer Agent                     com.mwr.dz

PS A:\PRIVIA SECURITY\Mobile Security\Security Tools\NoxPlayerEmulator\Nox\bin>
```

Yukarıdaki listelenmiş uygulamaların adını ve tanımlayıcısını görebiliriz. Bu durumda, “Medium” uygulaması “com.medium.reader” tanımlayıcısına sahiptir.

Burp Suite üzerinde proxy ayarının ayarlandığından emin olarak ardından uygulamanın SSL Sabitleme kullandığından emin olmak için uygulamayı açın.



Event log

Filter: **Critical** Error Info Debug

Search...

Time	Type	Source	Message
11:39:29 4 Tem 2022	Error	Proxy	[12] The client failed to negotiate a TLS connection to googleads.g.doubleclick.net:443: Received fatal alert: certificate_unknown
11:39:19 4 Tem 2022	Error	Proxy	[20] The client failed to negotiate a TLS connection to www.googleapis.com:443: Received fatal alert: certificate_unknown
11:39:19 4 Tem 2022	Error	Proxy	[52] The client failed to negotiate a TLS connection to www.googleapi.com:443: Received fatal alert: certificate_unknown
11:39:06 4 Tem 2022	Error	Proxy	[26] The client failed to negotiate a TLS connection to userlocation.googleapis.com:443: Received fatal alert: certificate_unknown
11:38:50 4 Tem 2022	Error	Proxy	[27] The client failed to negotiate a TLS connection to reminders-pa.googleapis.com:443: Received fatal alert: certificate_unknown
11:38:46 4 Tem 2022	Error	Proxy	[24] The client failed to negotiate a TLS connection to playatoms-pa.googleapis.com:443: Received fatal alert: certificate_unknown
11:38:37 4 Tem 2022	Error	Proxy	[7] The client failed to negotiate a TLS connection to b-graph.facebook.com:443: Received fatal alert: bad_certificate
11:37:39 4 Tem 2022	Error	Proxy	[16] The client failed to negotiate a TLS connection to biyeshen.com:443: Received fatal alert: certificate_unknown
11:37:33 4 Tem 2022	Info	Proxy	owasp.org is using HTTP/2
11:37:13 4 Tem 2022	Error	Proxy	[4] The client failed to negotiate a TLS connection to app-measurement.com:443: Received fatal alert: certificate_unknown
11:36:30 4 Tem 2022	Info	Proxy	beacons3.gvt2.com is using HTTP/2
11:36:29 4 Tem 2022	Info	Proxy	beacons.gvt2.com is using HTTP/2
11:36:28 4 Tem 2022	Info	Proxy	csi.gstatic.com is using HTTP/2
11:36:27 4 Tem 2022	Info	Proxy	googleads.g.doubleclick.net is using HTTP/2
11:36:27 4 Tem 2022	Info	Proxy	beacons.gvt2.com is using HTTP/2

```
objection -g com.medium.reader explore
```

```
android sslpinning disable
```

```
PS C:\Users\bulletproof> objectin -g com.medium.reader explore
Using USB device `SM-G973N`
Agent injected and responds ok!

_ _ _ | _ _ | _ _ _ | _ _ | _ _ _
|. | . | | _ | _ | _ | . |
| _ _ | _ _ | _ _ | _ _ | _ _ |
    | _ _ | (object)inject(ion) v1.11.0

Runtime Mobile Exploration
by: @leonjza from @sensepost

[tab] for command suggestions
com.medium.reader on (samsung: 7.1.2) [usb] # android sslpinning disable
(agent) Custom TrustManager ready, overriding SSLContext.init()
(agent) Found okhttp3.CertificatePinner, overriding CertificatePinner.check()
(agent) Found okhttp3.CertificatePinner, overriding CertificatePinner.check$okhttp()
(agent) Found com.android.org.conscrypt.TrustManagerImpl, overriding TrustManagerImpl.verifyChain()
(agent) Found com.android.org.conscrypt.TrustManagerImpl, overriding TrustManagerImpl.checkTrustedRecursive()
(agent) Registering job 310292. Type: android-sslpinning-disable
```

Bu adımların sonucunda aşağıdaki görselde SSL Pinning Bypass işleminin başarıyla gerçekleştirildiği görülür.

The image shows two side-by-side screenshots. The left screenshot is from Burp Suite, displaying an intercepted HTTP request to `https://api.medium.com:443`. The request is a POST to `/m/account/authenticate-email`. The body of the request is a JSON object: `{ "email": "furkanenes1160@gmail.com", "password": "1234567890", "onMobileWeb": false, "operation": "", "redirect": "", "resetPasswordFlow": false }`. A red box highlights the `"email": "furkanenes1160@gmail.com"` field, and a red arrow points to it. The right screenshot is from NoxPlayer 7.0.2.6, showing a web application interface for creating an account. The title is "What's your email?". Below the title, there is a text input field labeled "Your email" containing the text "furkanenes1160@gmail.com". A red box highlights this input field, and a red arrow points to it. Below the input field is a green button labeled "Continue".

Kapanış

Yukarıda anlatılan yöntemler işe yarayabilir de yaramayabilir de. Bu durum kullanılan uygulamaya ve SSL Pinning'in ne kadar karmaşık olduğuna bağlıdır. Umarım bu makale sizlere yardımcı olabilir.

Okuduğunuz için teşekkür ediyorum. Makale ile ilgili bir öneriniz varsa lütfen geri bildirimde bulunmayı unutmayın.

Saygılarımla.

Furkan Enes Polatoğlu